

CVE Report — Dependency Scan

Project: **vulnerable-invoice-service** · Stage 1 (OWASP Dependency-Check 11.x + Maven 3.9) · Generated 2026-06-22 · SHA: `61ed8c3`

Summary

Metric	Count
Dependencies scanned	24
CRITICAL CVEs	16
HIGH CVEs	37
MEDIUM CVEs	13
LOW CVEs	1
Total CVEs	67
Outdated dependencies	7
License violations	1
Supply-chain findings	2

Supply-Chain Alerts

CRITICAL — Typosquatted dependency. `com.fastxml.jackson.core:jackson-databind:2.9.8` — the groupId `com.fastxml` impersonates the legitimate `com.fasterxml.jackson.core` (missing the letters `er`). This coordinate does not exist on Maven Central and fails to resolve. This is an active supply-chain attack vector: if an attacker publishes a malicious artefact under this name on any accessible registry, it will be silently pulled into the build. **Remove immediately.**

HIGH — Untrusted HTTP repository. `pom.xml` declares `http://insecure-mirror.example.net/maven2` over plain HTTP. Any artefact fetched from this mirror is vulnerable to man-in-the-middle substitution. Maven 3.8+ blocks HTTP mirrors by default; this repo is already blocked by the internal mirror config, but its declaration must be removed to prevent accidental re-enablement. **Remove the `internal-untrusted-mirror` repository block.**

Known-Vulnerable Dependencies (Top CVE per Dependency)

Dependency	Version	Top CVE	CVSS	Severity	Fix Version
org.apache.logging.log4j:log4j-core	2.14.1	CVE-2021-44228 (Log4Shell)	10.0	CRITICAL	2.17.1
com.fasterxml.jackson.core:jackson-databind	2.9.8	CVE-2019-14379	9.8	CRITICAL	2.14.0
org.apache.logging.log4j:log4j-api	2.14.1	CVE-2026-34479	7.5	HIGH	2.24.3
mysql:mysql-connector-java	8.0.30	CVE-2023-22102	8.3	HIGH	8.0.31

com.google.protobuf:protobuf-java	3.19.4	CVE-2024-7254	7.5	HIGH	3.25.5
com.google.guava:guava	24.1.1-jre	CVE-2023-2976	7.1	HIGH	32.0.0-jre
com.fasterxml.jackson.core:jackson-annotations	2.9.0	CVE-2018-1000873	6.5	MEDIUM	2.9.8
org.apache.commons:commons-lang3	3.4	CVE-2025-48924	5.3	MEDIUM	3.20.0
commons-io:commons-io	2.4	CVE-2021-29425	4.8	MEDIUM	2.14.0

Full CVE Detail

org.apache.logging.log4j:log4j-core:2.14.1

CVE	CVSS	Severity	Description	Fix Version
CVE-2021-44228	10.0	CRITICAL	Log4Shell — remote code execution via JNDI lookup in log messages	2.17.1
CVE-2021-45046	9.0	CRITICAL	Incomplete fix for Log4Shell; RCE in non-default thread-context configurations	2.17.1
CVE-2026-34480	7.5	HIGH	Information disclosure / log injection via malformed event	2.24.3
CVE-2026-34479	7.5	HIGH	Denial of service via crafted log event	2.24.3
CVE-2021-44832	6.6	MEDIUM	RCE via attacker-controlled JDBC Appender configuration	2.17.2
CVE-2021-45105	5.9	MEDIUM	Infinite recursion / DoS via self-referential lookups	2.17.1
CVE-2025-68161	4.8	MEDIUM	Log injection via thread-context map manipulation	2.24.3
CVE-2026-34477	5.9	MEDIUM	Configuration injection shared with log4j-api	2.24.3

Recommended fix: upgrade to `2.17.1` immediately for Log4Shell remediation; target `2.24.3` for full coverage.

com.fasterxml.jackson.core:jackson-databind:2.9.8

This dependency carries **53 CVEs** — the largest blast radius in the project. All originate from unsafe polymorphic deserialization. Critical entries below; see `depscan-report.json` for the complete list.

CVE	CVSS	Severity	Description	Fix Version
CVE-2019-14379	9.8	CRITICAL	RCE via SubTypeValidator bypass	2.9.9.3
CVE-2019-14540	9.8	CRITICAL	RCE via com.zaxxer.hikari gadget chain	2.9.10
CVE-2019-14892	9.8	CRITICAL	RCE via commons-configuration2 gadget	2.9.10
CVE-2019-14893	9.8	CRITICAL	RCE via FasterXML serialization mishandling	2.9.10
CVE-2019-16335	9.8	CRITICAL	RCE via NettyJaxbEncoder gadget	2.9.10
CVE-2019-16942	9.8	CRITICAL	RCE via commons-dbcp2 gadget	2.9.10.1
CVE-2019-16943	9.8	CRITICAL	RCE via p6spy gadget	2.9.10.1
CVE-2019-17267	9.8	CRITICAL	RCE via xbean-reflect gadget	2.9.10
CVE-2019-17531	9.8	CRITICAL	RCE via logback gadget chain	2.9.10.1
CVE-2019-20330	9.8	CRITICAL	RCE via xslt gadget	2.9.10.2
CVE-2020-8840	9.8	CRITICAL	RCE via xslt/XALAN gadget	2.9.10.3
CVE-2020-9546	9.8	CRITICAL	RCE via shiro gadget	2.9.10.3
CVE-2020-9547	9.8	CRITICAL	RCE via ibatis-sqlmap gadget	2.9.10.3

CVE-2020-9548	9.8	CRITICAL	RCE via anteros-core gadget	2.9.10.3
CVE-2020-10672	8.8	HIGH	RCE via ignite-jta gadget	2.9.10.4
CVE-2020-10673	8.8	HIGH	RCE via commons-jelly gadget	2.9.10.4
CVE-2020-36518	7.5	HIGH	Uncontrolled resource consumption / OOM denial-of-service	2.13.2.1
CVE-2022-42003	7.5	HIGH	DoS via deeply nested arrays (resource exhaustion)	2.13.4.2
CVE-2022-42004	7.5	HIGH	DoS via BeanDeserializerBase <code>_deserializeFromArray</code>	2.13.4
... 34 more HIGH/MEDIUM CVEs	—	—	See <code>depscan-report.json</code> for full list	2.14.0

Recommended fix: upgrade to `2.14.0` — resolves all known deserialization gadget chains.

org.apache.logging.log4j:log4j-api:2.14.1

CVE	CVSS	Severity	Description	Fix Version
CVE-2026-34479	7.5	HIGH	Denial of service via log API misuse	2.24.3
CVE-2026-34477	5.9	MEDIUM	Configuration injection via public API	2.24.3

Recommended fix: upgrade in lockstep with `log4j-core` to `2.17.1` minimum, `2.24.3` preferred.

mysql:mysql-connector-java:8.0.30

CVE	CVSS	Severity	Description	Fix Version
CVE-2023-22102	8.3	HIGH	Server impersonation / MITM via <code>enabledTLSProtocols</code> misconfiguration	8.0.31

Additional finding: licensed under **GPL v2 with FOSS exception** — a licence-policy violation in a permissive-only project.

Recommended fix: upgrade to `8.0.33` ; review licence compatibility with legal counsel.

com.google.protobuf:protobuf-java:3.19.4

Transitive dependency via `mysql:mysql-connector-java`.

CVE	CVSS	Severity	Description	Fix Version
CVE-2024-7254	7.5	HIGH	Stack overflow via recursive protobuf parsing (DoS)	3.25.5
CVE-2022-3171	7.5	HIGH	Resource exhaustion via deeply nested messages	3.21.7
CVE-2022-3509	7.5	HIGH	DoS via text-format protobuf parsing	3.21.7
CVE-2022-3510	7.5	HIGH	DoS via binary-format protobuf parsing	3.21.7

Recommended fix: upgrade `mysql-connector-java` to `8.0.33` (pulls safe `protobuf-java`), or add an explicit `<dependencyManagement>` override to `3.25.5`.

com.google.guava:guava:24.1.1-jre

CVE	CVSS	Severity	Description	Fix Version
CVE-2023-2976	7.1	HIGH	Predictable temp-file creation allows local privilege escalation	32.0.0-jre
CVE-2020-8908	3.3	LOW	Insecure temporary directory on UNIX (information disclosure)	30.0-jre

Recommended fix: upgrade to `33.6.0-jre`.

com.fasterxml.jackson.core:jackson-annotations:2.9.0

Transitive dependency; resolved automatically when jackson-databind is upgraded.

CVE	CVSS	Severity	Description	Fix Version
CVE-2018-1000873	6.5	MEDIUM	Deserialization of untrusted data via @JsonDeserialize	2.9.8

org.apache.commons:commons-lang3:3.4

CVE	CVSS	Severity	Description	Fix Version
CVE-2025-48924	5.3	MEDIUM	Possible ReDoS via crafted string in RandomStringUtils	3.20.0

Recommended fix: upgrade to 3.20.0 .

commons-io:commons-io:2.4

CVE	CVSS	Severity	Description	Fix Version
CVE-2021-29425	4.8	MEDIUM	Partial path traversal in FileNameUtils.normalize()	2.7
CVE-2024-47554	4.3	MEDIUM	Denial of service via IOUtils.toInputStream with untrusted input	2.14.0

Recommended fix: upgrade to 2.22.0 .

Outdated Dependencies

Dependency	Current	Latest	Update Type
org.apache.logging.log4j:log4j-core	2.14.1	3.0.0-beta3	Major
org.apache.logging.log4j:log4j-api	2.14.1	3.0.0-beta2	Major
com.fasterxml.jackson.core:jackson-databind	2.9.8	2.22.0	Major
com.google.guava:guava	24.1.1-jre	33.6.0-jre	Major
commons-io:commons-io	2.4	2.22.0	Major
org.apache.commons:commons-lang3	3.4	3.20.0	Minor
mysql:mysql-connector-java	8.0.30	8.0.33	Patch

License Findings

Dependency	License	Status
mysql:mysql-connector-java:8.0.30	GPL v2 with FOSS exception	VIOLATION
org.checkerframework:checker-qual:2.0.0	GPL2 with classpath exception / MIT	WARN
All other compile-scope deps	Apache 2.0 / BSD-3 / MIT	OK